

ETHICAL HACKER - BENIPAYO

1. Which statement best describes the term ethical hacker?

a person who uses different tools than nonethical hackers to find vulnerabilities and exploit targets

a person that is financially motivated to find vulnerabilities and exploit targets

a person that is looking to make a point or to promote what they believe

☒ a person who mimics an attacker to evaluate the security posture of a network

2. Which threat actor term describes a well-funded and motivated group that will use the latest attack techniques for financial gain?

Which threat actor term describes a well-funded and motivated group that will use the latest attack techniques for financial gain?

hactivist

state-sponsored attacker

☒ organized crime

insider threat

3. Which type of threat actor uses cybercrime to steal sensitive data and reveal it publicly to embarrass a target?

organized crime

☒ hactivist

insider threat

state-sponsored attacker

4. What is a state-sponsored attack?

An attack perpetrated by a well-funded and motivated group that will typically use the latest attack techniques for financial gain.



An attack perpetrated by governments worldwide to disrupt or steal information from other nations.

An attack perpetrated by disgruntled employees inside an organization.

An attack is perpetrated to steal sensitive data and then reveal it to the public to embarrass or financially affect a target.

5. What is an insider threat attack?

An attack perpetrated by a well-funded and motivated group that will typically use the latest attack techniques for financial gain.

An attack perpetrated by governments worldwide to disrupt or steal information from other nations.



An attack perpetrated by disgruntled employees inside an organization.

An attack is perpetrated to steal sensitive data and then reveal it to the public to embarrass or financially affect a target.

6. What kind of security weakness is evaluated by application-based penetration tests?

firewall security



logic flaws

wireless deployment

data integrity between a client and a cloud provider

7. What two resources are evaluated by a network infrastructure penetration test?
(Choose two.)

- ☒ AAA servers
- ☐ CSPs
- ☐ web servers
- ☒ IPSs
- ☐ back-end databases

8. When conducting an application-based penetration test on a web application, the assessment should also include testing access to which resources?

- ☐ AAA servers
- ☐ cloud services
- ☐ switches, routers, and firewalls
- ☒ back-end databases

9. What is the purpose of bug bounty programs used by companies?

- ☒ reward security professionals for finding vulnerabilities in the systems of the company
- ☐ reward security professionals for discovering malicious activities by attackers in the systems of the company
- ☐ reward security professionals for fixing vulnerabilities in the systems of the company
- ☐ reward security professionals for breaking into a corporate facility to expose weaknesses in the physical perimeter

10. What characterizes a partially known environment penetration test?

The tester must test the electrical grid supporting the infrastructure of the target.

The tester is provided with a list of domain names and IP addresses in the scope of a particular target.



The test is a hybrid approach between unknown and known environment tests.

The tester should not have prior knowledge of the organization and infrastructure of the target.

11. What characterizes a known environment penetration test?

The test is somewhat of a hybrid approach between unknown and known environment tests.



The tester could be provided with network diagrams, IP addresses, configurations, and user credentials.

The tester should not have prior knowledge of the organization and infrastructure of the target.

The tester may be provided only the domain names and IP addresses in the scope of a particular target.

12. Which type of penetration test would only provide the tester with limited information such as the domain names and IP addresses in the scope?

known-environment test

partially known environment test



unknown-environment test

OWASP Web Security Testing Guide

13. Match the penetration testing methodology to the description.

Match the penetration testing methodology to the description.

Categories:		Options:
OWASP WSTG	A	D ✓ collection of different matrices of tactics and techniques that adversaries use while preparing for an attack
PTES	B	A ✓ covers the high-level phases of web application security testing
NIST SP 800-115	C	C ✓ provides organizations with guidelines on planning and conducting information security testing
MITRE ATT&CK	D	E ✓ lays out repeatable and consistent security testing
OSSTMM	E	B ✓ provides information about types of attacks and methods

14. Which three options are phases in the Penetration Testing Execution Standard (PTES)? (Choose three.)

- ✓ Threat modeling
- Penetration
- ✓ Reporting
- Enumerating further
- Network mapping
- ✓ Exploitation

15. Which two options are phases in the Information Systems Security Assessment Framework (ISSAF)? (Choose two.)

☐	Pre-engagement interactions
☒	Maintaining access
☐	Reporting
☐	Post-exploitation
☒	Vulnerability identification

16. Which two options are phases in the Open Source Security Testing Methodology Manual (OSSTMM)? (Choose two.)

☐	Vulnerability Analysis
☐	Maintaining Access
☒	Work Flow
☐	Network Mapping
☒	Trust Analysis

17. Which penetration testing methodology is a comprehensive guide focused on web application testing?

☐	MITRE ATT&CK
☒	OWASP WSTG
☐	NIST SP 800-115
☐	OSSTMM

18. Which option is a Linux distribution that includes penetration testing tools and resources?

OWASP

PTES

SET

☒ BlackArch

19. Which option is a Linux distribution URL that provides a convenient learning environment about pen testing tools and methodologies?

vmware.com

attack.mitre.org

☒ parrotsec.org

virtualbox.org

20. What does the "Health Monitoring" requirement mean when setting up a penetration test lab environment?

The tester needs to be sure that a lack of resources is not the cause of false results.

☒ The tester needs to be able to determine the causes when something crashes.

The tester needs to ensure controlled access to and from the lab environment and restricted access to the internet.

The tester validates a finding running the same test with a different tool to see if the results are the same.

21. Which tool would be useful when performing a network infrastructure penetration test?

- vulnerability scanning tool
- ☒ bypassing firewalls and IPSs tool
- interception proxies tool
- mobile application testing tool

22. Which tool should be used to perform an application-based penetration test?

- sniffing traffic tool
- bypassing firewalls and IPSs tool
- ☒ interception proxies tool
- cracking wireless encryption tool

23. Which tools should be used to perform a wireless infrastructure penetration test?

- web vulnerability detection tools
- traffic manipulation tools
- proxy interception tools
- ☒ de-authorizing network devices tools

24. Which tools should be used for testing the server and client platforms in an environment?

☐ cracking wireless encryption tools

☒ vulnerability scanning tools

☐ interception proxies tools

☐ de-authorizing network devices tools

25. Sometimes a tester cannot virtualize a system to do the proper penetration testing. What action should be taken if a system cannot be tested in a virtualized environment?

☒ a full backup of the system

☐ rebuild the system after any test is performed

☐ adopt penetration test tools that will certainly not damage the system

☐ a complete report with recommended repairs

26. A contractor is hired to review and perform cybersecurity vulnerability assessments for a local health clinic facility. Which U.S. government regulation must the contractor understand before the contractor can start?

☒ HIPAA

☐ GLBA

☐ GDPR

☐ FedRAMP

27. An Internal Revenue Service office in New York is considering moving some services to a cloud computing platform. Which U.S. government regulation must the office follow in the process?

☐	FFIEC
☐	HIPAA
☒	FedRAMP
☐	GDPR

28. An US university in California plans to offer online courses to students in partner universities in France and Germany. Which regulation should the university follow when those courses are offered?

☐	FedRAMP
☐	FERPA
☒	GDPR
☐	HIPAA

29. Which U.S. government agency is responsible for enforcing the Privacy of Consumer Financial Information Rule of the Gramm-Leach-Bliley Act (GLB Act)?

☐	Federal Deposit Insurance Corporation (FDIC)
☐	Securities and Exchange Commission (SEC)
☐	Commodity Futures Trading Commission (CFTC)
☒	Federal Trade Commission (FTC)

30. In the healthcare sector, which term defines an entity that processes nonstandard health information it receives from another entity into a standard format?

health plan

healthcare provider

☒ healthcare clearinghouse

business associates

31. In the healthcare sector, which term is used to define an entity that provides payment for medical services?

healthcare provider

☒ health plan

healthcare clearinghouse

business associates

32. In e-commerce, what determines the application of the Payment Card Industry Data Security Standard (PCI DSS) requirements?

primary account number

33. What are two examples of sensitive authentication data associated with a payment card that requires compliance with the Payment Card Industry Data Security Standard (PCI DSS)? (Choose two.)

primary account number

cardholder name

☒ CAV2/CVC2/CVV2/CID

expiration date

☒ full magnetic strip data or equivalent data on a chip

34. Match the parts of Recommendation for Key Management in the NIST SP 800-57 to the description.

Match the parts of Recommendation for Key Management in the NIST SP 800-57 to the description.

Categories:		Options:
Part 1: General	A	☒ provides guidance when using the cryptographic features of current systems
Part 3: Application Specific Key Management Guidance	B	☒ provides guidance on policy and security planning requirements for U.S. government agencies
Part 2: Best Practices for Key Management Organization	C	☒ provides general guidance and best practices for the management of cryptographic keying material

35. An employee of a cybersecurity consulting firm in the U.S. is assigned to help assess the system and operation vulnerabilities of several financial institutions in Europe. The task includes penetration tests for compliance. What is a key element the employee must have before starting the assignment?

☐ detailed network diagrams and asset inventories from each client institution

☒ documentation of permission for performing the tests from the client institutions

☐ valid user credentials to perform tests at each client institution

☐ state-of-the-art penetration testing tools

36. A company hires a cybersecurity professional to perform penetration tests to assess government regulation compliance. Which legal document should be provided to the cybersecurity professional that specifies the expectations and constraints, including quality of work, timelines, and cost?

service-level agreement (SLA)

37. A company hires a cybersecurity professional to perform penetration testing to assess government regulation compliance. Which document will be provided to the cybersecurity professional that specifies a detailed and descriptive list of all the deliverables, including the scope of the project, the timeline and report delivery schedule, the location of the work, and the payment schedule?

☐ non-disclosure agreement (NDA)

☐ service-level agreement (SLA)

☒ statement of work (SOW)

☐ master service agreement (MSA)

38. A company hires a cybersecurity consultant to perform penetration testing to assess

ETHICAL HACKER - BENIPAYO

government regulation compliance. The company wants the consultant to disclose information to them and no one else. Which type of NDA agreement should be presented to the consultant?

☐	multilateral DNA
☐	bilateral NDA
☒	unilateral NDA
☐	mutual NDA

39. A company hires a cybersecurity consultant to perform penetration testing to assess government regulation compliance. Which document must the consultant receive that specifies the agreement between the consultant and the company for the penetration testing engagement?

☐	disclaimers
☐	non-disclosure agreement
☐	statement of work
☒	contract

40. A company hires a cybersecurity consultant to perform penetration testing to assess government regulation compliance. The consultant is preparing the final report after the penetration testing is completed. In which section of the report should the consultant cover the limitation of the work performed, such as the only dates when the testing is performed and that the findings mentioned in the report do not guarantee that all vulnerabilities are covered?

☐	non-disclosure statement
☐	findings and analysis
☐	scope of work
☒	disclaimers

41. A company hires a cybersecurity consultant to perform penetration tests and review the rules of engagement documents. What are three examples of typical elements in the rules of engagement document? (Choose three.)

location of testing (correct)

☒ testing timeline

☐ location of testing

☒ unknown-environment testing condition

☐ non-disclosure agreement

☐ payment schedule

☒ preferred method of communication

42. A company hires a cybersecurity consultant to perform penetration tests and review the rules of engagement documents. The consultant notices that one element specifies that the tests should be performed toward only web applications on websites `www1.company.com` and `www2.company.com`, with no social engineering attacks and no cross-site scripting attacks. Which element in the document is used for the specification?

☐ IP addresses or networks from which testing will originate

☐ the security controls that could potentially detect or prevent testing

☒ types of allowed or disallowed tests

☐ location of testing

43. A company hires a cybersecurity consultant to assess applications using different APIs. Which document should the company provide to the consultant about an XML-based language used to document a web service's functionality?

☐ Swagger (OpenAPI) documentation

☐ Web Application Description Language (WADL) document

☐ GraphQL documentation

☒ Web Services Description Language (WSDL) document

44. A company hires a cybersecurity consultant to assess applications using different APIs. Which document should the company provide to the consultant about a query language for APIs and a language for executing queries at runtime?

Swagger (OpenAPI) documentation

☒ GraphQL documentation

Web Application Description Language (WADL) document

Web Services Description Language (WSDL) document

45. A company hires a cybersecurity consultant to assess vulnerability on crucial web application devices such as web and database servers. Which document should the company provide to help the consultant document and define what systems are in the testing?

software development kit (SDK) for specific applications

examples of application requests

☒ system and network architectural diagram

source codes of the applications

46. A company hires a cybersecurity consultant to perform penetration tests. What can cause scope creep of the engagement?

lack of up-to-date testing tools

lack of system and network architectural diagrams

poor formatted request for proposal (RFP) by the company

☒ ineffective identification of what technical and nontechnical elements will be required for the penetration test

47. A company hires a cybersecurity consultant to perform penetration tests. What should be the consultant's first step in validating the engagement scope?

Request user credentials in accessing targeted systems.

Confirm the contents of the request for proposal (RFP).

Ensure that systems and network architectural diagrams are accurate.

☒ Question the company contact person and review contracts.

48. A company hires a cybersecurity consultant to perform penetration tests. The consultant is

ETHICAL HACKER - BENIPAYO

working with the company to set up communication procedures. Which two protocols should be considered for exchanging emails securely? (Choose two.)

- ☐ SFTP
- ☐ HTTPS
- ☐ SCP
- ☒ S/MIME
- ☒ PGP

49. A company hires a cybersecurity consultant to perform penetration tests. The consultant is discussing with the company about the penetration testing strategy. Which statement describes the term unknown-environment testing?

- ☒ This type of testing is where the consultant will be provided with very limited information about the targeted systems and network.
- ☐ This type is a type of testing where the budget can be further negotiated throughout the testing.
- ☐ This is a type of testing where the time frame of the work can be flexible and extension is possible.
- ☐ This is a type of testing where the scope of the work could be extended later.

50. A company hires a cybersecurity consultant to perform penetration tests. What is the key difference between unknown-environment testing and known-environment testing?

- ☐ the tools and types of tests allowed during testing
- ☒ the amount of information provided to the consultant
- ☐ credentials and certificates required of the consultant
- ☐ the types of systems and network to be tested

SUMMATIVE 2

51. Which two tools could be used to gather DNS information passively? (Choose two.)

DIG and recon-ng

☒ Recon-ng

☐ Nmap

☐ ExifTool

☒ Dig

52. When performing passive reconnaissance, which Linux command can be used to identify the technical and administrative contacts of a given domain?

☒ whois

☐ nmap

☐ dig

☐ netstat

53. Which specification defines the format used by image and sound files to capture metadata?

☒ Exchangeable Image File Format (Exif)

☐ Exchangeable File Format (EFF)

☐ Interchangeable File Format (IFF)

☐ Extensible Image File Format (Exif)

54. Why would a penetration tester perform a passive reconnaissance scan instead of an active one?

because the root-level SSH credentials to a target have been compromised

to test whether specific services or protocols are available on the network

☒ to collect information about a network without being detected

because the time to perform the scan is limited

55. What type of server is a penetration tester enumerating when they enter the **nmap -sU** command?

HTTP or HTTPS server

☒ DNS, SNMP, or DHCP server

FTP server

POP3, IMAP, or SMTP server

56. What is the disadvantage of conducting an unauthenticated scan of a target when performing a penetration test?

Unauthenticated scans are more likely to provide a lower rate of false positives than authenticated scans.

Unauthenticated scans are a form of passive reconnaissance that return little useful information.

The scanner will report the port as open whether or not the service on that network segment is listening or not.

☒ Vulnerability of services running inside the target may not be detected.

57. What is required for a penetration tester to conduct a comprehensive authenticated scan against a Linux host?

- system user credentials
- physical on-premises access to the target system
- ☒ user credentials with root-level access to the target system
- backdoor access to the target system
- unauthenticated scans are a form of passive reconnaissance that return little useful information.

58. In which circumstance would a penetration tester perform an unauthenticated scan of a target?

- when only targets with UDP services are to be scanned
- when time is limited and faster scans are required
- ☒ when user credentials were not provided
- when the number of false positive vulnerability reports is not required

59. Why would a penetration tester use the **nmap -sF** command?

- when the tester needs to time stamp the scan
- when the tester wants to conclude the scan
- ☒ when a TCP SYN scan is detected by a network filter or firewall
- when a TCP SYN scan reports more than one open port

60. What is the purpose of host enumeration when beginning a penetration test?

to count the total number of vulnerable hosts within the scope of the test

☒ to identify all active IP addresses within the scope of the test

to identify all vulnerable hosts within the scope of the test

to count the total number of IP addresses within the scope of the test

61. What can be deduced when a tester enters the **nmap -sF** command to perform a TCP FIN scan and the target host port does not respond?

☒ that the port is open

that the port is not ready to close the TCP connection

that the port is not responding to TCP traffic

that the port is listening for UDP traffic

62. What is the disadvantage of running a TCP Connect scan compared to running a TCP SYN scan during a penetration test?

Indeterminate ICMP messages are generated.

Both open and closed ports are detected.

Hosts and addresses outside the scope of the test may be scanned.

☒ The extra packets required may trigger an IDS alarm.

63. When a penetration test identifies a vulnerability, how should the vulnerability be further verified?

- mitigate the vulnerability
- prioritize the vulnerability severity
- assess the business risk associated with the vulnerability
- ☒ determine if the vulnerability is exploitable

64. Why is the Common Vulnerabilities and Exposures (CVE) resource useful when investigating vulnerabilities detected by a penetration test?

- ☒ It is an international consolidation of cybersecurity tools and databases.
- It has three vulnerability score components.
- It is a dictionary of known attacks.
- It is a high level list of software weaknesses.

65. What is the purpose of applying the Common Vulnerability Scoring System (CVSS) to a vulnerability detected by a penetration test?

- to determine the priority of the vulnerability
- to determine the attack vector that applies to the vulnerability
- ☒ to calculate the severity of the vulnerability
- to accurately record how the vulnerability was detected

66. A threat actor is looking at the IT and technical job postings of a target organization. What would be the most beneficial information to capture from these postings?

the salaries of the positions listed

☒ the type of hardware and software used

the employment benefits offered by the company

the hours of work required by the roles listed

67. How is open-source intelligence (OSINT) gathering typically implemented during a penetration test?

by installing and running the OSINT API

by using nmap for web page and web application enumerations

☒ by using public internet searches

by sending phishing emails

68. What initial information can be obtained when performing user enumeration in a penetration test?

access to the target internal network

the IP addresses of the target hosts

☒ a valid list of users

the credentials of a specified user

69. What useful information can be obtained by running a network share enumeration scan during a penetration test?

☒ systems on a network that are sharing files, folders, and printers

☐ lists of the attack vectors that can exploit the network

☐ all vulnerable hosts on the network

☐ the usernames and password credentials of users on the network

70. A penetration tester must run a vulnerability scan against a target. What is the benefit of running an authenticated scan instead of an unauthenticated scan?

☐ Authenticated scans are a form of passive reconnaissance that does not trigger target security alarms.

☐ Authenticated scans are less complex and are quicker than unauthenticated scans.

☐ Authenticated scans are performed without user credentials.

☒ Authenticated scans can provide a more detailed picture of the target attack surface.

71. What are three considerations when planning a vulnerability scan on a target production network during a penetration test? (Choose three.)

☐ authenticated scans are less complex and are quicker than unauthenticated scans

☐ the scan reporting requirement

☒ the network topology

☒ the available network bandwidth

☐ the trained personnel available to analyze the scan results

☐ the available scanning tools

☒ the timing of the scan

72. When performing a vulnerability scan of a target, how can adverse impacts on traversed devices be minimized?

☒ The scan should be performed as close to the target as possible.

☐ Only passive reconnaissance scans should be performed.

☐ Unauthenticated vulnerability scans should be performed.

☐ Scanning policy options should include query throttling.

73. A company hires a cybersecurity consultant to conduct a penetration test to assess vulnerabilities in network systems. The consultant is preparing the final report to send to the company. What is an important feature of a final penetration test report?

☐ It is made publicly available to all interested parties.

☐ It is a summary of general information so non-technical managers can understand it.

☐ It follows expected report presentation standards and style.

☒ It gives an accurate presentation of vulnerabilities.

74. What is the advantage of using the target Wi-Fi network for reconnaissance packet inspection?

☒ Physical access to the building may not be required.

☐ The packet scan takes less time wirelessly compared to using the target wired network.

☐ More information can be captured wirelessly compared to using the target wired network.

☐ Fewer false positive vulnerabilities are detected.

75. What guidance does the NIST Cybersecurity Framework provide to help improve an organization's cybersecurity posture?

☐ The framework provides a global consolidation of cybersecurity tools and databases.

☒ The framework outlines standards and industry best practices.

☐ The framework lists cyber attacks that have been seen in the real world.

☐ The framework provides a vulnerability scoring system.

76. What type of threat allows an attacker to obtain the credentials of a bank client by spoofing the login webpage of a financial institution?

☐ piggybacking

☐ whaling

☐ vishing

☒ malvertising

77. What is a watering hole attack?

an attack carried out in a phone conversation

☒ an attack that exploits a website that is commonly accessed by members of a targeted organization

an attack targeted at high-profile business executives and key individuals in a company

an attack performed by an unauthorized person who tags along with an authorized person to gain entry to a restricted area

78. What is the act of gaining knowledge or information from a victim without directly asking for that particular information?

influence

interrogation

☒ elicitation

impersonation

79. A threat actor has altered the host file for a commonly accessed website on the computer of a victim. Now when the user clicks on the website link, they are redirected to a malicious website. What type of attack has the threat actor accomplished?

vishing

phishing

tailgating

☒ pharming

80. Why would a threat actor use the Social-Engineering Toolkit (SET)?

☒ to send a spear phishing email

☐ to spoof a phone number

☐ to practice social engineering elicitation, interrogation, and pretexting skills

☐ to manipulate users by leveraging XSS vulnerabilities

81. Which option is a voice over IP management tool that can be used to impersonate caller ID?

☐ Nikto

☐ SpoofApp

☐ SpoofCard

☒ Asterisk

82. A salesperson is attempting to convince a customer to buy a product because limited supplies are available. Which social engineering method of influence is being used by the salesperson?

☒ scarcity

☐ likeness

☐ authority

☐ social proof

83. What method of influence is characterized when a celebrity endorses a product on social media?

Multiple choice question interface showing four options: fear, scarcity, social proof (selected), and authority.

Options:

- fear
- scarcity
- ☒ social proof
- authority

84. Apple is a company constantly working towards making its products and processes more environmentally friendly. Therefore, the Apple brand is associated with ideals and values that customers can relate to and support. What method of influence is being used by Apple?

Multiple choice question interface showing four options: authority, scarcity, fear, and likeness (selected).

Options:

- authority
- scarcity
- fear
- ☒ likeness

85. A threat actor has sent a phishing email to a victim stating that suspicious activity has been detected on their bank account and that they must immediately click on a provided link to change their password. What method of influence is being used by the threat actor?

Multiple choice question interface showing four options: social proof, urgency (selected), likeness, and authority.

Options:

- social proof
- ☒ urgency
- likeness
- authority

86. Which social engineering physical attack statement is correct?

☒ Shoulder surfing can be prevented by using special screen filters for computer displays.

☐ In the piggybacking attack, an unauthorized person tags along with an authorized person to gain entry to a restricted area without the person's consent.

☐ Badge cloning attacks cannot be performed by software.

☐ In the tailgating attack, an unauthorized person tags along with an authorized person to gain entry to a restricted area with the person's consent.

87. Which tool provides a threat actor a web console to manipulate users who are victims of cross-site scripting (XSS) attacks?

☐ SET

☐ Nikto

☐ Asterisk

☒ BeEF

88. Which Apple iOS and Android tool can be used to spoof a phone number?

☐ BeEF

☐ Asterisk

☐ Nessus

☒ SpoofApp

89. What two physical attacks are mitigated by using access control vestibules?
(Choose two.)

dumpster diving

☒ tailgating

☒ piggybacking

badge cloning

shoulder surfing

90. Which two access control options are commonly used in conjunction with access control vestibules? (Choose two.)

security guard

☒ biometric scan

toll collector

turnstile

☒ proximity card and PIN

91. Which resource would mitigate piggybacking and tailgating?

☒ security guard

camera

badge/card access

"no trespassing" warnings

92. Which tool can launch social engineering attacks and be integrated with third-party tools and frameworks such as Metasploit?

☐	Asterisk
☐	BeEF
☐	Nessus
☒	SET

93. Who is the target of a whaling attack?

☐	companies that use animals in product testing
☐	ordinary users
☒	upper managers such as the CEO or key individuals in an organization
☐	user groups of social networks such as Facebook and Twitter

94. What is the purpose of a vishing attack?

☒	to convince a victim on a phone call to disclose private or financial information
☐	to use text messages to send malware or malicious links to mobile devices of users
☐	to create emails and web pages to collect sensitive information from a user
☐	to use USB sticks to compromise the systems of victims

95. Which Apple iOS and Android tools can spoof a phone number, record calls, and generate different background noises?

Nessus

BeEF

Asterisk

 SpoofCard

96. A threat actor has sent a text message to a victim stating that they have won bitcoins in a bank contest. To claim their prize, the victim must click the provided link and enter their bank account information. What social engineering attack can be accomplished if the user enters their banking information?

watering hole

vishing

whaling

 SMS phishing

97. Which tool permits post-exploitation activities, such as Windows reverse VNC DLL and reverse TCP shell?

 SET

BeEF

Nikto

Nessus

98. Which tool can send fake notifications to the browser of a victim?

☐	Asterisk
☐	Nikto
☒	BeEF
☐	Nexpose

99. A new employee is celebrating their position with a large company by posting a picture of their access identification on social media. What kind of physical attack has the new employee unknowingly enabled?

☐	shoulder surfing
☐	pivot
☐	watering hole
☒	badge cloning

100. A user has found a USB pen drive in the corporate parking lot. What should the user do with this pen drive?

☐	plug the pen drive into a computer of the company, try to delete all the files, and use the pen drive for personal use
☐	throw the pen drive away
☐	plug the pen drive into a computer of the company, try to access the files to identify who the pen drive belongs to
☒	deliver the pen drive to the security sector of the company

101. Which NetBIOS service is used for connection-oriented communication?

LLMNR

NetBIOS-DGM

☒ NetBIOS-SSN

NetBIOS-NS

102. Match the port type and number with the respective NetBIOS protocol service.

Categories:		Options:	
TCP port 445	A	D	☒ NetBIOS Datagram Service
TCP port 139	B	B	☒ NetBIOS Session Service
UDP port 137	C	E	☒ Microsoft Remote Procedure Call (MS-RPC)
UDP port 138	D	C	☒ NetBIOS Name Service
TCP port 135	E	A	☒ SMB protocol

103. What two features are present on DNS servers using BIND 9.5.0 and higher that help mitigate DNS cache poisoning attacks? (Choose two.)

- ☐ secure DNS data authentication
- ☒ provision of cryptographically secure DNS transaction identifiers
- ☐ exclusion of any trust relationships between DNS servers
- ☒ randomization of ports
- ☐ prevention of any recursive DNS queries

104. What UDP port number is used by SNMP protocol?

- ☐ 182
- ☐ 176
- ☒ 161
- ☐ 128

105. Which is a characteristic of a DNS poisoning attack?

- ☐ The DNS server IP address is changed.
- ☒ The DNS resolver cache is manipulated.
- ☐ The DNS server forward lookup zone is cleared.
- ☐ The DNS server reverse lookup zone is cleared.

106. Which Kali Linux tool or script can gather information on devices configured for SNMP?

☒ snmp-check

snmp-brute.nse

snmp-netstat.nse

nslookup

107. Match the SMTP command with the respective description.

Categories:		Options:
HELO	A	☒ used to initiate the transfer of the contents of an email message
DATA	B	☒ used to cancel an email transaction
STARTTLS	C	☒ used to initiate an SMTP conversation with an email server
RSET	D	☒ used to denote the email address of the sender
EHELO	E	☒ used to initiate a conversation with an Extended Simple Mail Transport Protocol server
MAIL	F	☒ used to start a Transport Layer Security connection to an email server

Connections: A-B, B-D, C-E, D-F, E-C, F-A

108. Which two best practices would help mitigate FTP server abuse and attacks? (Choose two.)

consolidate all back-end databases on the FTP server

☒ require re-authentication of inactive sessions

☒ use encryption at rest

edit the hosts file to limit the number of authorized DNS servers

limit anonymous logins to a select group of people

109. Which is a characteristic of the pass-the-hash attack?

☒ capture of a password hash (as opposed to the password characters) and using the same hashed value for authentication and lateral access to other networked systems

reverse engineering of the captured hash password and using the unencrypted password for authentication and lateral access to other networked systems

compromise of a SAM file and extraction of the password characters to use for authentication and lateral access to other networked systems

capture of the Windows password before the Kerberos hashing function and use of the unencrypted password for authentication and lateral access to other networked systems

110. What is a Kerberoasting attack?

☒ It is a post-exploitation attempt that is used to extract service account credential hashes from Active Directory for offline cracking.

It attempts to manipulate data being transferred by performing data corruption or modification.

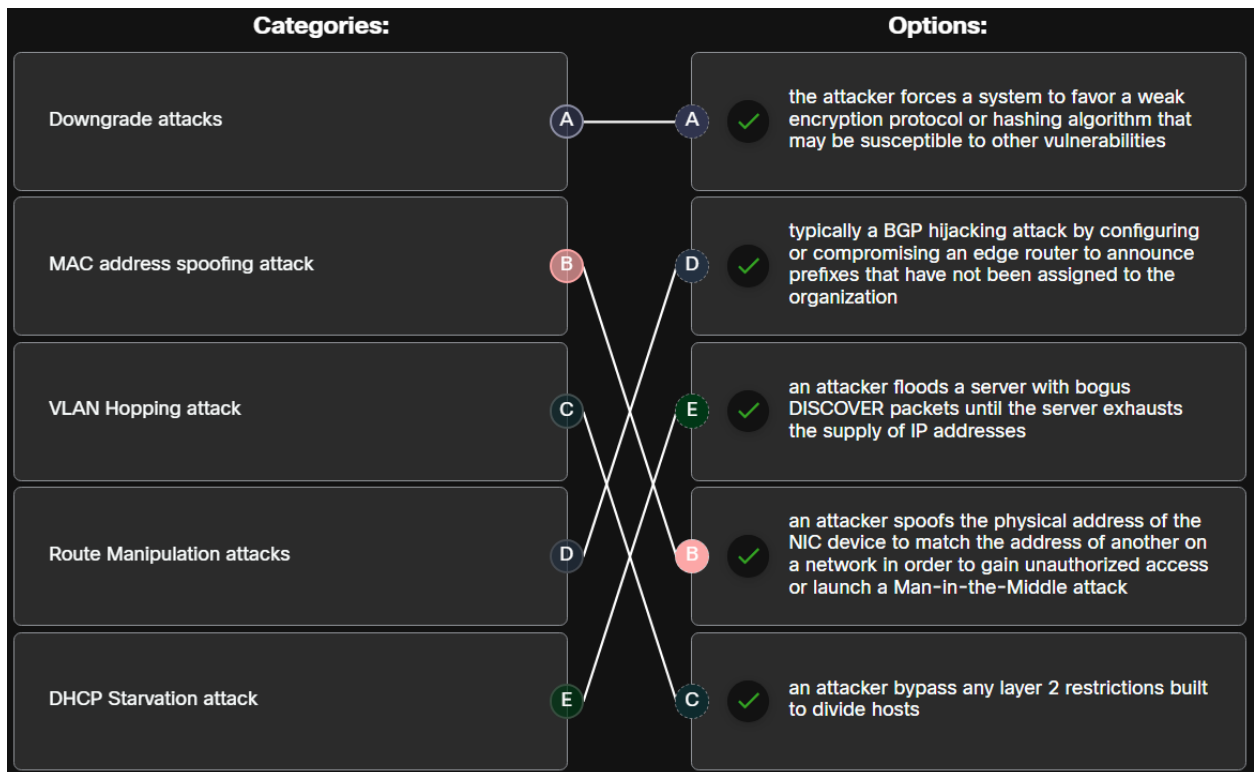
It is an attempt to steal the hash value of a user credential and use it to create a new user session on the same network.

It attempts to manipulate Kerberos tickets based on available hashes by compromising a vulnerable system and obtaining the local user credentials and password hashes.

111. Match the attack type with the respective description.

Categories:		Options:
DDOS	A	☒ This an attack in which the attacker exploits vulnerabilities in target servers to initially turn small queries into much larger payloads, which are used to bring down the servers of the victim.
Reflected DOS	B	☒ This occurs when the source of the attack generates the packets, regardless of protocol, application, and so on, that are sent directly to the victim of the attack.
DNS Amplification	C	☒ This attack uses botnets that can be manipulated from a command and control (CnC, or C2) system.
Direct DOS	D	☒ This attack uses spoofed packets that appear to be from the victim. Then the sources become unwitting participants in the attack by sending the response traffic back to the intended victim.

112. Match the attack type with the respective description.



113. Which tool can be used to perform a Disassociation attack?

☐ nmap

☐ POODLE

☒ Airmon-ng

☐ EMPIRE

114. Which is a characteristic of a Bluesnarfing attack?

An attack involves modifying BLE messages between systems that would lead them to believe that they are communicating with legitimate systems.

An attack that can be performed using Bluetooth with vulnerable devices in range. It is commonly performed as spam over Bluetooth connections using the OBEX protocol.

☒ An attack that can be performed using Bluetooth with vulnerable devices in range. This attack actually steals information from the device of the victim.

An attack that is launched using common social engineering attacks, such as phishing attacks, can be performed by impersonating a wireless AP or a captive portal to convince a user to enter the user credentials.

115. Which Wi-Fi protocol is most vulnerable to a brute-force attack during a Wi-Fi network deployment?

WPA2-TKIP

WPA2-EAP

☒ WPS

WPA3

116. What does the MFP feature in the 802.11w standard do to protect against wireless attacks?

It uses a PNL to maintain a list of trusted or preferred wireless networks.

☒ It helps defend against deauthentication attacks.

It inserts the 802.1q tag to protect the wireless frame.

It uses a captive portal for all wireless associations.

117. What is a DNS resolver cache on a Windows system?

It is a collective database of all Domain Name Service records of static and cached entries.

☒ It is a temporary database that contains records of all the recent visits and attempted visits to websites and other internet domains.

It is a database of all WINS records.

It is a static database entry of all forward and reverse lookup zones.

118. Match the TCP port number with the respective email protocol that uses it.

Categories:		Options:
143	A	☒ The Secure SMTP (SSMTP) protocol for encrypted communications, as defined in RFC 2487, using STARTTLS.
465	B	☒ The default port used by the IMAP protocol in encrypted (SSL/TLS) communications.
587	C	☒ The port registered by the Internet Assigned Numbers Authority (IANA) for SMTP over SSL (SMTPS).
995	D	☒ The default port used by the POP3 protocol in encrypted communications.
993	E	☒ The default port used by the IMAP protocol in non-encrypted communications.

119. Which is the default TCP port used in SMTP for non-encrypted communications?

993

☒ 25

110

143

120. What is a characteristic of a Kerberos silver ticket attack?

It mimics the authentication hash on a particular server.

It acts as the LDAP directory for authentication on a target server.

It converts the hashed value to the unencrypted value for an authentication attack on a particular server.

☒ It uses forged service tickets for a given service on a particular server.

121. Which attack is a post-exploitation activity that an attacker uses to extract service account credential hashes from Active Directory for offline cracking?

On-Path attack

MAC spoofing

MITM

☒ Kerberoasting

122. Which four items are needed by an attacker to create a silver ticket for a Kerberos silver ticket attack? (Choose four.)

DNS resolver cache

☒ target service

☒ SID

☒ FQDN

hash value

☒ system account

DNS reverse lookup zone

DNS forward lookup zone

123. Which kind of attack is an IP spoofing attack?

Evil-Twin

DDoS

Pass-the-Hash

☒ On-path

124. What is a common mitigation practice for ARP cache poisoning attacks on switches to prevent spoofing of Layer 2 addresses?

DNSSEC

☒ DAI

BIND 9.5

DHCP snooping

125. An attacker is launching a reflected DDoS attack in which the response traffic is made up of packets that are much larger than those that the attacker initially sent. Which type of attack is this?

ETHICAL HACKER - BENIPAYO

☐	DNS cache poisoning
☒	amplification
☐	on-path
☐	downgrade

126.